

Manual 29 — Garantia da cadeia de suprimentos de software e IA — Edição controlada pt-BR

Status: tradução controlada não oficial do projeto. Preserva a separação entre obrigações vinculantes, padrões publicados, especificações voluntárias e orientações de implementação.

Hierarquia de fontes controlada

- Lei, regulamento, cláusula de contratação pública e contrato aplicáveis mantêm prioridade vinculante.
- NIST SP 800-218 SSDF versão 1.1 é a linha de base final estável utilizada.
- NIST SP 800-218A é o perfil comunitário final de IA utilizado com o SSDF 1.1.
- SLSA versão 1.2 é a especificação aprovada vigente utilizada.
- Orientações da CISA e fontes semelhantes são tratadas como orientação, salvo quando outra fonte as tornar obrigatórias.
- NIST SP 800-218 Rev. 1 / SSDF versão 1.2 permanece em rascunho e sob monitoramento de mudanças.

Cada capítulo preserva aplicabilidade, responsável, procedimento, evidência, revisão/teste, remediação e gatilho de reavaliação.

Capítulo 01 — Objetivo, escopo e limites de fontes

Definir o escopo de software, modelos, componentes, fornecedores, produtos, jurisdições, contratos e aquisições antes de selecionar controles. Evidência: declaração de escopo e registro de fontes. Responsável: líder de garantia da cadeia de suprimentos.

Capítulo 02 — Inventário do ecossistema de fornecedores e componentes

Manter inventário com responsável relacionando fornecedores materiais, pacotes, modelos, APIs, fontes de dados, serviços de build, hospedagem e dependências de produto. Evidência: registro e mapa de dependências.

Capítulo 03 — Governança e responsabilidades de desenvolvimento seguro

Estabelecer política, funções responsáveis, segregação de funções, escalonamento, autoridade para exceções e objetivos mensuráveis. Evidência: política, RACI, cartas e registro de exceções.

Capítulo 04 — Preparação organizacional do SSDF

Mapear práticas SSDF aplicáveis para procedimentos, ferramentas, treinamento, requisitos de segurança e expectativas de fornecedores sem apresentar orientação do NIST como certificação. Evidência: matriz de implementação SSDF.

Capítulo 05 — Segurança do ambiente de desenvolvimento

Manter linhas de base aprovadas para ambientes de desenvolvimento, build, teste e treinamento de modelos, incluindo acesso, configuração, atualização, monitoramento e mudança conforme o risco.

Capítulo 06 — Governança de código-fonte e repositórios

Usar repositórios controlados com propriedade definida, acesso autenticado, proteção de branches, política de revisão, auditabilidade, retenção e recuperação.

Capítulo 07 — Identidade, acesso e administração privilegiada de build

Aplicar privilégio mínimo, identidades gerenciadas, autenticação forte apropriada, revisão periódica de acesso e acesso emergencial controlado nas plataformas relevantes.

Capítulo 08 — Controles de branches, revisão e mudanças

Exigir mudanças rastreáveis, independência de revisão proporcional ao risco, verificações obrigatórias, caminhos de merge controlados e tratamento documentado de mudanças emergenciais.

Capítulo 09 — Descoberta de dependências e inventário de componentes

Identificar dependências diretas, transitivas, de execução, build, modelo, plugin e ferramenta por métodos aprovados e atribuir responsável aos componentes materiais.

Capítulo 10 — Geração, formatos e ciclo de vida de SBOM

Gerar e manter SBOM legível por máquina quando aplicável, vinculá-lo a versões controladas, definir formatos aceitos e validar identidade e relações dos componentes.

Capítulo 11 — VEX e evidência do estado de vulnerabilidades

Quando forem usadas declarações de estado de vulnerabilidade, vinculá-las a produto/versão, identificador, justificativa, evidência, responsável e gatilho de revisão.

Capítulo 12 — Entrada de código aberto e interfaces de licenciamento

Avaliar procedência, manutenção, histórico de segurança, obrigações de licença, avisos, restrições e uso/distribuição pretendidos antes de aprovar componentes abertos.

Capítulo 13 — Garantia de bibliotecas e pacotes de terceiros

Usar fontes aprovadas, versões ou identificadores imutáveis quando prático e critérios documentados de aceitação de componentes/fornecedores.

Capítulo 14 — Segurança de serviços de build e CI/CD

Governar CI/CD com configurações aprovadas, acesso administrativo restrito, definições protegidas, integrações controladas, registros de auditoria e revisão de mudanças.

Capítulo 15 — Considerações de build hermético/reprodutível

Avaliar entradas não declaradas, variabilidade de ambiente, deriva de ferramentas e necessidades de reprodutibilidade; aplicar técnicas apropriadas quando justificadas por risco ou obrigação.

Capítulo 16 — Assinatura e verificação de artefatos

Definir autoridade de assinatura, identidades ou chaves aprovadas, processo protegido, política de verificação, revogação e requisitos de verificação pelo consumidor.

Capítulo 17 — Arquitetura de proveniência e atestações

Gerar proveniência ou atestações a partir de processos confiáveis, vinculá-las a identidades imutáveis e definir política de verificação. Evidência: atestações e resumos de verificação.

Capítulo 18 — Implementação das trilhas Build e Source do SLSA

Selecionar objetivos aplicáveis de trilha/nível SLSA v1.2, documentar lacunas, satisfazer requisitos antes de fazer declarações e distinguir maturidade interna de certificação externa.

Capítulo 19 — Governança de segredos, chaves, tokens e material de assinatura

Usar armazenamento aprovado, credenciais com escopo reduzido, rotação, controle de acesso, monitoramento e procedimentos de incidente para segredos de desenvolvimento e cadeia de suprimentos.

Capítulo 20 — Garantia de contêineres, imagens e componentes de infraestrutura

Usar fontes aprovadas, versões controladas, controles de vulnerabilidade e integridade, registros de linhagem e assinatura/verificação conforme o risco.

Capítulo 21 — Proveniência de modelos de IA e controles de sua cadeia de suprimentos

Registrar origem, versão, fornecedor, linhagem de treinamento/ajuste quando disponível, restrições de licença/uso, identificadores de integridade, avaliação, responsável e dependências materiais.

Capítulo 22 — Proveniência de dados de treinamento e avaliação

Registrar fonte, autorização ou licença, sensibilidade, qualidade, transformações, linhagem, retenção e limitações de uso de dados materiais.

Capítulo 23 — Governança de componentes, plugins, ferramentas e agentes de IA

Inventariar componentes e serviços de suporte a IA, documentar permissões e limites de confiança, exigir evidência de fornecedor/proveniência e reavaliar mudanças materiais.

Capítulo 24 — Garantia de modelos, APIs e provedores de serviços externos

Avaliar segurança, privacidade, disponibilidade, tratamento de dados, notificação de incidentes, subcontratados, direitos de evidência, mudanças, saída e compromissos contratuais.

Capítulo 25 — Descoberta, priorização e resposta a vulnerabilidades

Relacionar vulnerabilidades a produtos/componentes afetados, priorizar conforme o risco, atribuir compromissos de remediação, validar o fechamento e manter decisões de risco.

Capítulo 26 — Governança de fontes de pacotes e integridade de dependências

Governar namespaces, registros aprovados, nomes de componentes, mudanças de fornecedor, sinais de integridade e comportamento inesperado de dependências para revisão de anomalias materiais.

Capítulo 27 — Aprovação de release, distribuição e rollback

Exigir gates de release, identidade do artefato, testes necessários, verificações de proveniência/assinatura, SBOM/VEX quando aplicável, autoridade de aprovação, distribuição controlada e capacidade de rollback.

Capítulo 28 — Resposta a incidentes e comprometimento da cadeia de suprimentos

Integrar cenários de comprometimento de fornecedores, componentes, repositórios, build, assinatura, modelos e dados à resposta a incidentes, recuperação e ações corretivas.

Capítulo 29 — Métricas, exceções e aceitação de risco

Medir propriedade de dependências, cobertura de verificação, cobertura SBOM, idade de vulnerabilidades, atualização de evidência de fornecedores, exceções e objetivos de garantia. Exigir aceitação de risco com prazo.

Capítulo 30 — Garantia, testes e validação de evidências

Executar garantia independente baseada em risco por inspeção de evidências, revisão de configuração, verificação de artefatos/proveniência, rastreabilidade de releases e testes de operação de controles.

Capítulo 31 — Localização, acessibilidade, licenciamento e controle de fontes

Manter paridade controlada EN/es-419/pt-BR, identificar traduções do projeto como não oficiais, preservar limites de licença/fonte e validar acessibilidade, renderização e controle de versão.

Capítulo 32 — Roteiro de release, proveniência, checksums e publicação sequencial

Gerar candidatos DOCX/PDF reproduzíveis EN/es-419/pt-BR, vincular identidades SHA-256 e digest do artefato, executar QA determinístico sem regeneração, armazenar exatamente os bytes verificados, exigir Manual 28 publicado e reconciliar o estado somente com uma matriz final totalmente verde.